

Cyberster Internship Program

Internship Report

TRACK: BLUE TEAM

NAME: MUHAMMAD RAZA

INSTRUCTOR: ABDULLAH ZIA

ROLL NUMBER: CSI-B1-121

WEEK 6: Insider Threat Simulation and Incident Response

1. Executive Summary

An insider threat simulation was conducted to test the organization's detection and response capabilities against "Living-off-the-Land" (LotL) techniques. A simulated malicious actor with local access created a sensitive data file, obfuscated it using the native Windows certutil.exe utility, and exfiltrated it to an external server via PowerShell. The actor then deleted the local files to evade detection.

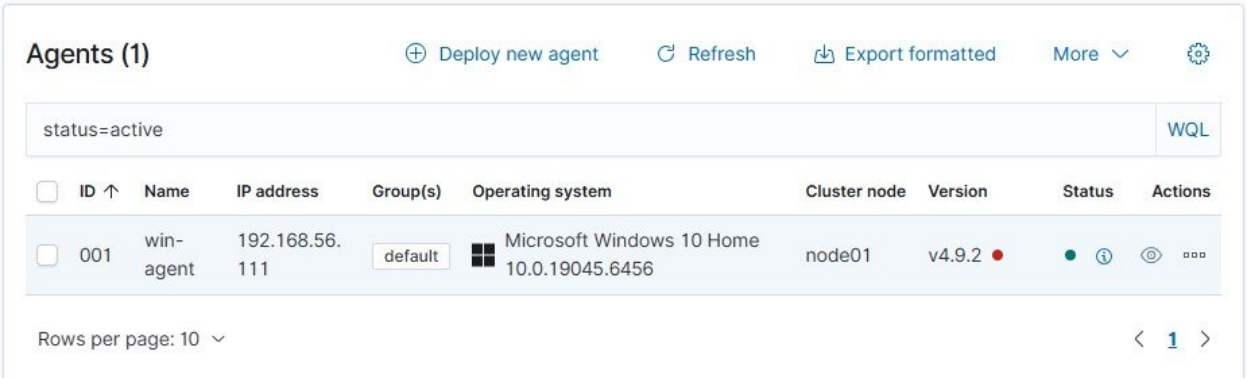
While traditional endpoint defenses did not block the native execution, Wazuh File Integrity Monitoring (FIM) successfully captured the file lifecycle (creation, modification, deletion). This telemetry allowed the Blue Team to reconstruct the attack chain, decode the exfiltrated artifacts, and engineer a custom detection rule to automate alerting for future occurrences.

2. Environment & Visibility Setup

A controlled lab environment was established, consisting of:

- **Victim Endpoint:** Windows Virtual Machine
- **Adversary Endpoint:** Kali Linux Virtual Machine
- **SIEM:** Wazuh Manager & Dashboard

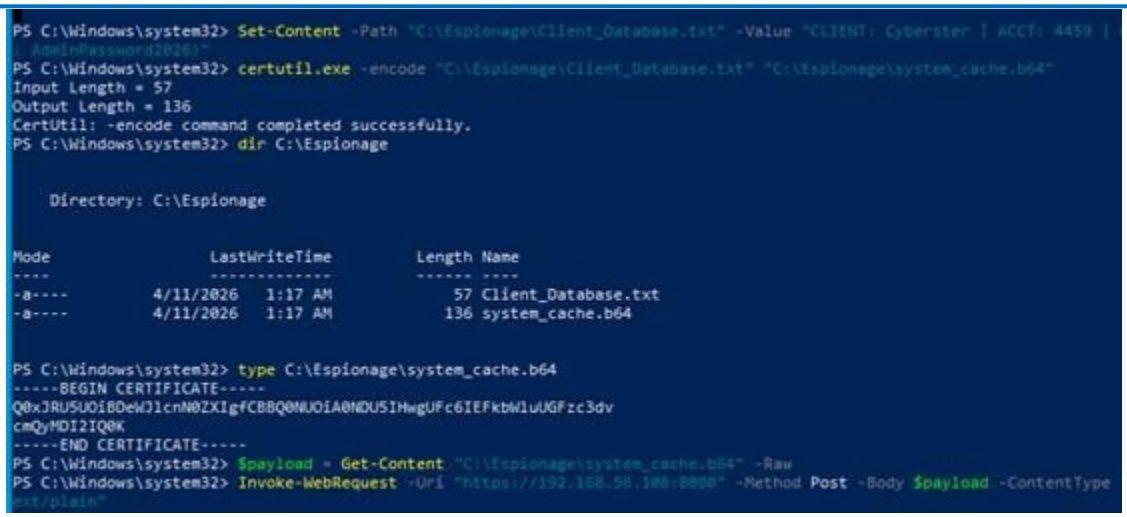
To ensure comprehensive visibility, a dedicated staging directory (C:\Espionage) was created on the Windows endpoint. The Wazuh agent was configured (ossec.conf) to monitor this directory in real-time (realtime="yes") for all file attribute changes.

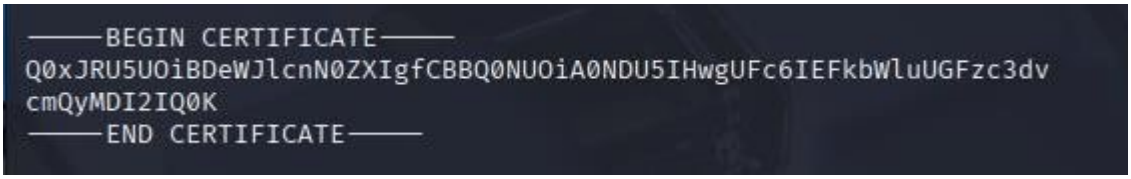


3. Attack Simulation (Red Team)

The simulated attack followed a precise execution chain utilizing built-in Windows utilities to bypass traditional antivirus controls:

1. **Command & Control:** A Netcat listener was established on the Kali attacker machine (Port 8080).
2. **Data Staging:** A sensitive file (Client_Database.txt) was created in C:\Espionage.
3. **Obfuscation:** The file was encoded into Base64 format (system_cache.b64) using the legitimate certutil.exe certificate management tool.
4. **Exfiltration:** The encoded data was transmitted to the attacker's listener via HTTP POST using PowerShell's Invoke-WebRequest.
5. **Defense Evasion:** All files in the staging directory were securely deleted using Remove-Item -Force to destroy forensic evidence.





4. Detection & Analysis (Blue Team)

The SOC team investigated the incident using Wazuh alerts and external forensic tools.

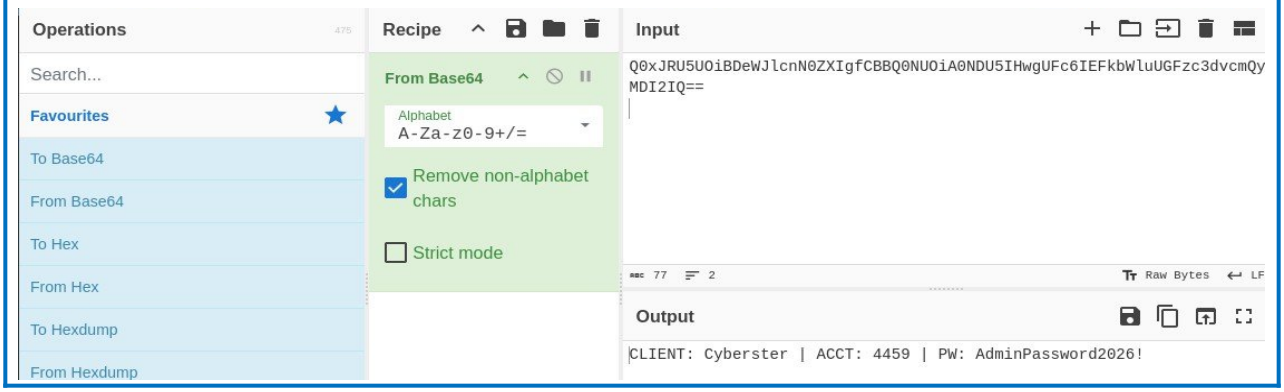
Wazuh FIM Alert Correlation

The attack triggered a sequential pattern of FIM alerts that, while individually low-severity, indicated malicious intent when correlated:

- **Rule 554 (File Added):** Triggered by the creation of Client_Database.txt and system_cache.b64.
- **Rule 550 (File Modified):** Triggered during the certutil encoding process, altering file checksums.
- **Rule 553 (File Deleted):** Triggered by the rapid mass deletion of the directory contents immediately following the modification, strongly indicating anti-forensic activity.

Artifact Decoding

The intercepted Base64 payload was analyzed and decoded using CyberChef, confirming that sensitive client credentials (account numbers and passwords) were successfully compromised.



MITRE ATT&CK Mapping & IOCs

Technique	Tactic	Observed Behavior	Tool/Indicator
T1074	Collection	Staging sensitive data	C:\Espionage\Client_ Database.txt
T1027	Defense Evasion	Base64 encoding	certutil.exe, .b64 extension
T1048	Exfiltration	HTTP POST data transfer	Invoke-WebRequest, Port 8080
T1070.004	Defense Evasion	File deletion	Remove-Item

5. Detection Engineering

To automate the detection of this specific LotL behavior, a custom Wazuh rule (**Rule ID: 100003**) was engineered. The rule alerts on the creation of .b64 files within monitored high-risk directories, elevating the severity to Level 10.

```
<rule id="100003" level="10">
<if_sid>554</if_sid>
<field name="file" type="pcre2">(?i)C:\\Espionage\\.+\.b64</field>
<description>Possible Data EXfiltration</description>
<mitre>
<id>T1027</id>
</mitre>
</rule>
```



6. Incident Response & Remediation

Following the detection of the exfiltration, the following response actions are required:

- **Containment:** Disable the compromised user's account and temporarily isolate the endpoint from the network to prevent further data loss.
- **Eradication:** Scan the system for persistent scheduled tasks or unauthorized scripts.
- **Recovery:** Mandate a password reset for all exposed credentials within the exfiltrated database.
- **Policy Improvements:** * Deploy Custom Rule 100003 to the production SIEM environment.
    - Enable PowerShell Script Block Logging (Event ID 4104) to catch memory-based execution.
    - Restrict the execution of LOLBins (like certutil.exe) using Windows Defender Application Control (WDAC) or AppLocker for non-administrative users.

7. Conclusion

This simulation highlighted the inherent risks of insider threats utilizing native, trusted system tools to conduct espionage. Because the attacker relied entirely on legitimate binaries, standard signature-based detection failed. However, by leveraging robust File Integrity Monitoring, correlating sequential file behaviors, and implementing custom detection engineering, the SOC successfully identified the breach, recovered the exfiltrated payload, and hardened the environment against future attacks.